

Assignment-3
Set-3

Siva kumar m
192551057
CSA-5117

97
100
hash functions

(a) What is the purpose of HMAC over plain hash functions
HMAC stands for Hash-based message Authentication Code. It has a mechanism used to provide message integrity and authentication using a cryptographic hash function together with a secret key.

A plain hash function such as SHA-256, takes a message as input and produces a fixed length hash value. However, a plain hash does not prove that the message was generated by an authorized sender because anyone can calculate hash of message.

HMAC solves this problem by combining a secret key with the message before applying the hash function.

The general HMAC construction is

$$\text{HMAC}(K, m) = H[(K \oplus \text{opad}) \parallel H((K \oplus \text{ipad}) \parallel m)]$$

Where

K = Secret key

K^L = key adjusted to block size of hash function

M = Message

H = cryptographic hash function

ipad = inner padding

- ⊕ - outer padding
- ⊗ - xor operation
- || - concatenation

Purpose of HMAC:

HMAC provides the following security properties:

(i) message integrity:

It ensures that the message has not been modified during transmission.

(ii) message authentication:

It verifies that message was generated by someone who possesses the shared secret key.

(iii) protection against unauthorized modification:

an attacker who does not know the secret key cannot easily generate a valid HMAC for modified message.

HMAC vs plain hash

for example if we use SHA-256 ("hello") any one can know the message can calculate same hash.

But with

HMAC-SHA-256 ("secret", "hello") the attacker also needs the secret key to generate correct code. therefore HMAC is preferred over plain

S 011. 015.

Frequency attack on additive cipher

Alr

Alm:

To implement

Given message = "hello", key = 'secret' hash = SHA-256. explain in steps how Hmac will be calculated

Given

message (M) = "hello"

Secret key = "secret"

hash function = SHA-256

HMAC calculation uses standard HMAC construction

$$\text{HMAC}(K, M) = H[K' \oplus \text{Dpad}] \parallel H[K' \oplus \text{ipad} \parallel M]$$

Sha-256 has 512-bit block size, so key is first prepared to fit block.

Step 1: Prepare Secret Key

The given key is

$K = \text{"secret"}$

The key is converted into binary 1 byte

Since the key is shorter than 512-bit (bytes) of SHA-256 it padded with zeros to obtain block length.

The resulting key is represented as K' .

Step 2: Create inner padded key

The prepared key K' is XORed with standard inner padding

$ipad = 0x36$ repeated for 64 bytes

Therefore:

$K' \oplus ipad$ is calculated

Step 3: Append the message

The message

$M = \text{'hello'}$

is concatenated with inner padded

$(K' \oplus ipad) || \text{'hello'}$

Step 4: Calculate the inner SHA-256 hash

SHA-256 is applied to result

$H_{\text{inner}} = \text{SHA-256}[(K' \oplus ipad) || \text{'hello'}]$

This produces 256 bit (32 bytes) inner hash value

Step 5: Create outer padded key

The prepared key K' is now XORed with standard outer padding

The outer padding is

Opad = 0x5c repeated for 64 bytes

Therefore

$K' \oplus \text{Opad}$ is calculated

Step 6: Append the inner hash

The inner hash obtained in step 4 is concatenated with outer padded key

$(K' \oplus \text{Opad}) \parallel H_{\text{inner}}$

Step 7: Calculate the final SHA-256 hash

SHA-256 is applied again

$\text{HMAC} = \text{SHA-256}((K' \oplus \text{Opad}) \parallel H_{\text{inner}})$

The final result is HMAC $\oplus$ SHA-256 authentication code

Flow of HMAC calculation

key "Secret"

↓

Pad key to 512 bits

↓

XOR with ipad (0x36)

↓

Append "hello"

↓

SHA-256

↓

Inner hash
 ↓
 XOR key with opad (0x5c)
 ↓
 Append inner hash
 ↓
 SHA-256
 ↓
 final HMAC - SHA-256

Result:

The final HMAC is a 256-bit (32 byte) Authentication Code.

Qc) Why is it not advisable to use MD5 in hmac for security critical applications?

MD5 is cryptographic hash function that produces a 128-bit message digest. However, MD5 has significant cryptographic weakness particularly collision vulnerabilities.

A collision occurs when attacker is able to find two different message that produce the same hash value.

$$M_1 \neq M_2$$

but

$$MD5(M_1) = MD5(M_2)$$

Because practical collision attacks against MD5 are known, it is considered cryptographically broken for many security application.

Although Hmac provides additional protection by incorporating a Secret key, using MD5 is not security, critical application is not recommended because MD5 is an outdated hash algorithm with known weaknesses.

Reason avoiding HMAC-MD5 in security critical applications

1. MD5 has known collision attacks
2. It has relatively short 128-bit output
3. It is considered obsolete for modern cryptographic application
4. Stronger hash function such as SHA-256 are readily available.
5. Security-critical system should use modern algorithm with stronger security margins.

Therefore HMAC-SHA-256 is better choice than HMAC-MD5 for security-critical applications

(d) How does a MAC differ from digital signature in terms of authentication and non-repudiation

A MAC (message authentication code) and a digital signature both provide message authentication and integrity, but they differ in their keys and ability to provide non-repudiation.

MAC

A MAC uses a shared secret key between the sender and receiver.

The sender calculates:

$$MAC = MAC(\text{key}, \text{message})$$

The receiver uses the same secret key to verify mac.

Therefore a mac provides

- * message authentication
- * message integrity

however it does not provide strong non-repudiation because the sender and receiver possess the same secret key. either party could potentially have generated the Mac.

Digital Signature.

a digital signature uses asymmetric cryptography

The sender has:

- * Private key for signing
- * Public key for verification

The sender signs the message using private key, and anyone with corresponding public key can verify the signature

A digital signature provides

message authentication

message integrity

Non-repudiation

Signature	MAC	Digital Signature
Cryptography	Symmetric	Asymmetric
Key used	Shared secret key	Private and public key
Authentication	Yes	Yes
Integrity	Yes	Yes
Non-repudiation	No	Yes
Verification	Requires shared secret	Public key can verify
Typical use	Secure communication between parties sharing a secret	Secure documents, certificates, transactions etc

Conclusion:

A mac is suitable when ~~to~~ two parties shared a secret key and needed authentication and integrity. ~~at~~ a digital signature

is more suitable when public verification and non-repudiation required

Thus major difference is that mac provides integrity but not repudiation, whereas digital signature can provide integrity and non-repudiation